

# Project Proposal: AWS Data Protection, Encryption & Privacy Compliance

## Members:

- Marwa Abdullah Ouf Elzoghby
- Nadine Amr Sayed Fahmy
- Omar Mohsen Emam Youssef
- Zyad Ahmed Mahmoud Ibrahim
- Dina Bahy Mostafa El-shiekh
- Haneen Mosad Mohammed Elgebaly

Instructor: Samah Esia

## 1. Overview

Data is what attackers are after, and in the cloud it is easy to lose control of it: a public S3 bucket, an unencrypted database, a secret hardcoded in code, or sensitive records nobody knew were stored. This project builds a complete data protection setup on AWS. We classify the data, encrypt it at rest and in transit, manage keys and secrets properly, find sensitive data automatically, and map everything to GDPR, HIPAA, and PCI-DSS.

The result is a working, audit-ready data security baseline with evidence for every control.

## 2. Objectives

- Map the data lifecycle and classify data into clear sensitivity levels.
- Lock down S3 with bucket policies, versioning, encryption, access points, and Block Public Access.
- Encrypt data at rest across S3, RDS, DynamoDB, EBS, and Glacier using a planned KMS key hierarchy.
- Protect data in transit with TLS and ACM, and manage secrets with Secrets Manager and Parameter Store.
- Discover sensitive data with Macie, watch for data threats with GuardDuty, and plan DLP controls.
- Map our controls to GDPR, HIPAA, and PCI-DSS and show we are ready for an audit.

### 3. Scope

Everything in the four weekly phases below, using synthetic data only. CloudHSM is covered as a concept because of cost.

### 4. Planned Architecture

A sample app with an S3 data lake, RDS, DynamoDB, and EBS volumes, all encrypted under a KMS key hierarchy with separate keys per sensitivity level. ACM secures every connection with TLS, secrets live in Secrets Manager, and Macie and GuardDuty watch the data for sensitive content and suspicious access.

### 5. Weekly Plan

#### Week 1: Data Lifecycle, Classification & S3 Security

We map the data lifecycle, define a classification scheme, and build a secure S3 baseline: bucket policies, versioning, default encryption, access points, Access Analyzer, Block Public Access, and lifecycle rules.

Deliverables: data classification scheme, S3 secure baseline, bucket policy examples, access review, lifecycle policy, data handling standard.

#### Week 2: Encryption at Rest & Key Management

We build a KMS key hierarchy with key policies and rotation, cover CloudHSM as a concept, encrypt S3, RDS, DynamoDB, EBS, and Glacier, and run a KMS lab.

Deliverables: KMS key hierarchy, key policy design, encrypted data stores, KMS lab evidence, key rotation and audit plan.

#### Week 3: Encryption in Transit, Secrets & API Protection

We deploy TLS with ACM, enforce HTTPS only, move credentials into Secrets Manager with rotation, use Parameter Store for config, and add API protection.

Deliverables: TLS/ACM setup, certificate inventory, secrets rotation design, API security controls, data-in-transit architecture.

## Week 4: Data in Use, DLP, Privacy & Compliance

We run Macie on synthetic data, use GuardDuty for data threats, write a DLP plan, and map controls to GDPR, HIPAA, and PCI-DSS.

Deliverables: Macie findings report, DLP plan, compliance control matrix, data protection risk register, final audit-ready data security report.

## 6. Tools & Services

AWS: S3, Access Analyzer, KMS, CloudHSM (concept), RDS, DynamoDB, EBS, Glacier, ACM, Secrets Manager, Systems Manager Parameter Store, API Gateway, Macie, GuardDuty, CloudTrail, Security Hub, IAM.

## 7. Risks & Cost Control

| Risk                                        | Mitigation                                                    |
|---------------------------------------------|---------------------------------------------------------------|
| Macie and GuardDuty costs                   | Scan small synthetic datasets and set an AWS Budget alert.    |
| Deleting a KMS key makes data unrecoverable | Use deletion waiting periods and test only on throwaway data. |
| Vague compliance mapping                    | Map each control to a specific AWS setting and evidence.      |

## 8. Success Criteria

- No S3 bucket is publicly accessible, and Access Analyzer confirms it.
- All data stores are encrypted with the planned KMS keys, and rotation is on.
- All traffic uses TLS, and no secrets appear in code or config files.
- Macie finds the sensitive data we planted in the synthetic datasets.
- Every GDPR, HIPAA, and PCI-DSS control in the matrix points to an AWS setting and evidence.
- Every deliverable listed in the project booklet is submitted, and each member can explain their part.